

Fail-safe edge-AI vision dishwasher-picker robot

Owner: MDU

Reviewer:

Contributors:

Date Generated: Mon Sep 14 2026



OWASP Threat Dragon

Executive Summary

High level system description

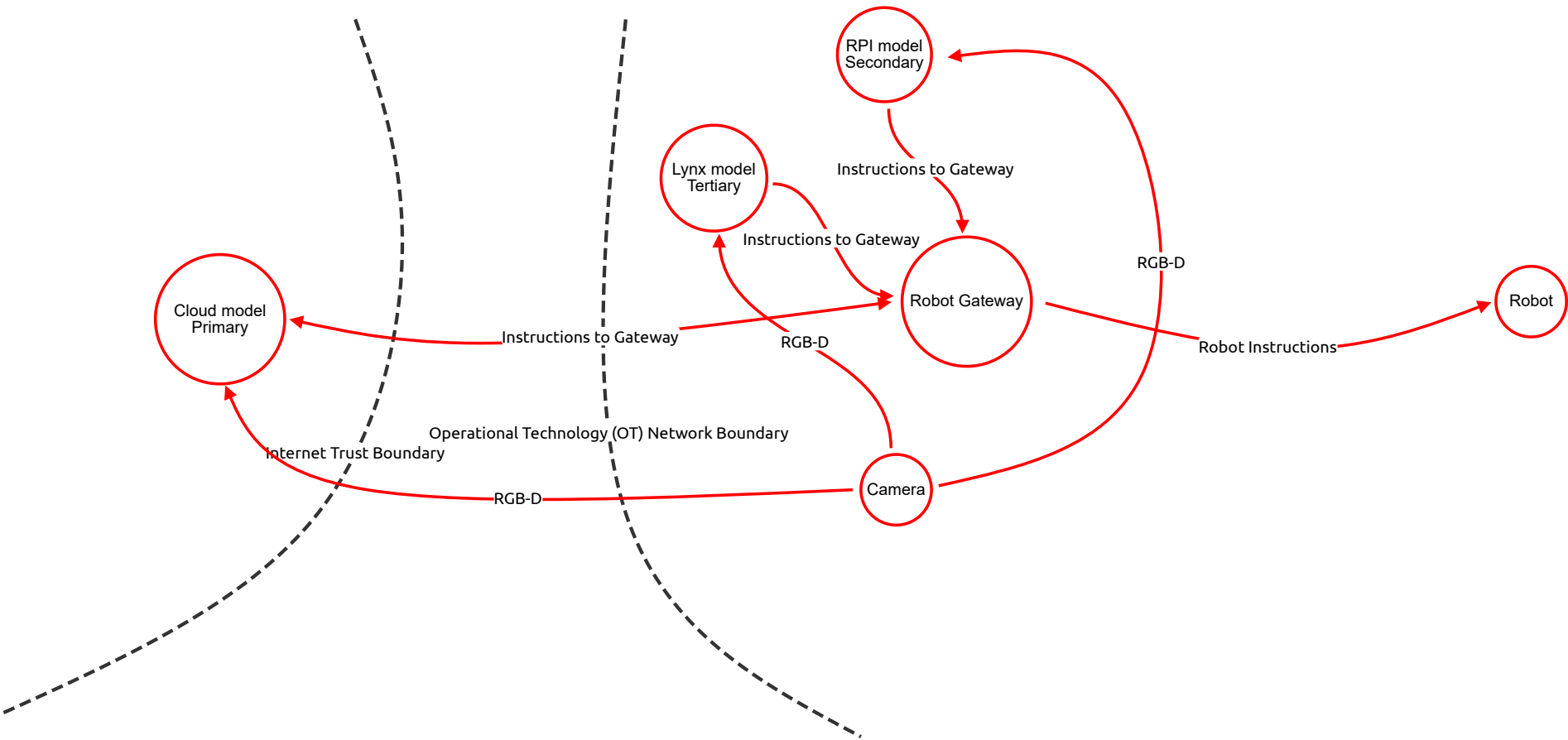
Full system, ai dishwasher with cloud compute and edge backups/failsafes to ensure proper operation of robot

Summary

Total Threats	51
Total Mitigated	0
Total Open	51
Open / Critical Severity	8
Open / High Severity	15
Open / Medium Severity	22
Open / Low Severity	4
Open / TBD Severity	2

Gatewayed STRIDE

STRIDE for a central Gateway



Gatewayed STRIDE

Robot (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Spoofed Robot Commands	Spoofing	High	Open		An attacker attempts to impersonate the Robot Gateway and transmit commands directly to the robot. If the robot cannot verify the identity of the sender, unauthorized instructions may be accepted, resulting in unintended robot movement, disruption of operations, or physical damage.	The robot should only accept connections from the Robot Gateway over a dedicated network segment. Source authentication should be enforced using mutual authentication or allow-listed endpoints, while network segmentation and firewall rules should prevent unauthorized devices from communicating with the robot.
16	Compromised Robot Gateway	Elevation of privilege	Critical	Open		An attacker gains control of the Robot Gateway and uses its trusted relationship with the robot to issue unauthorized commands. Since the gateway is the sole command path, the attacker effectively gains control over robot operations.	Harden the gateway through secure configuration, software integrity controls, monitoring, and strict access management. Commands should also be validated against safety policies before reaching the robot.
17	Unsafe but Authenticated Commands	Tampering	TBD	Open		The robot receives a command from a trusted source that is syntactically valid but would result in unsafe behavior, such as collisions, excessive speed, or movement outside the intended workspace.	Validate all incoming commands against safety constraints, operational limits, and workspace restrictions before execution.
18	Unauthorized Physical Access to Robot Network Port	Spoofing	Medium	Open		An attacker gains physical access to the robot's Ethernet interface and connects an unauthorized device to the network, potentially bypassing logical security controls.	Restrict physical access to the robot and networking equipment through controlled access areas and secured enclosures. Network access controls should prevent unauthorized devices from communicating with the robot.

RGB-D (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	Manipulated RGB-D Data	Tampering	High	Open		An attacker modifies RGB-D data transmitted from the camera to an AI model. The altered data may cause incorrect object detection, pose estimation, or scene understanding, resulting in inappropriate robot commands being generated.	Communications between the camera and AI systems should be authenticated and integrity protected. AI-generated commands should also be validated independently by the Robot Gateway before reaching the robot.
29	Camera Feed Interception	Information disclosure	Medium	Open		An attacker gains access to RGB-D streams transmitted across the network. Captured data may reveal operational procedures, robot activities, facility layouts, or information about manipulated objects.	Camera traffic should be encrypted and restricted to authorized recipients. Network segmentation should limit visibility of camera streams to approved systems only.
30	Camera Stream Unavailable	Denial of service	High	Open		The camera stream becomes unavailable due to network failures, hardware faults, power loss, or malicious interference. AI systems may lose visibility of the environment and become unable to generate reliable instructions.	AI models should detect missing or stale image data and stop generating movement instructions. The Robot Gateway should reject commands generated from outdated sensor information and transition the system to a safe state if required.

Robot Instructions (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	Modified Commands in Transit	Tampering	High	Open		An attacker intercepts traffic between the Robot Gateway and the robot and modifies valid instructions before they are executed. A legitimate movement command could therefore be altered into an unintended action while still appearing to originate from a trusted source.	Communications between the gateway and robot should be protected using authenticated encryption. Message integrity verification and cryptographic authentication should ensure that any modification of commands is detected before execution.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	Replay of Valid Robot Commands	Tampering	Medium	Open		An attacker captures legitimate communication between the Robot Gateway and the robot and retransmits previously valid commands. Commands may then be executed outside their intended operational context.	Use timestamps, sequence numbers, or unique message identifiers to detect and reject replayed messages.
14	Loss of Communication with Gateway	Denial of service	Medium	Open		Communication between the Robot Gateway and the robot may be disrupted through network failures, cable disconnection, hardware faults, or malicious traffic, preventing the robot from receiving instructions.	Implement connection monitoring through heartbeats and communication timeouts. When communication is lost, the robot should enter a predefined safe state.
15	Eavesdropping on Robot Communications	Information disclosure	Medium	Open		An attacker monitors traffic between the Robot Gateway and the robot to obtain operational information, command data, status messages, or network details that could assist future attacks.	Encrypt all communications between the gateway and robot using secure protocols that provide confidentiality and integrity protection.

Instructions to Gateway (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Modified Local AI Instructions	Tampering	Medium	Open		An attacker with access to the local network alters instructions sent from the Raspberry Pi model to the Robot Gateway.	Authenticate and encrypt communications within the local network and verify message integrity at the gateway.
25	Disclosure of AI Outputs	Information disclosure	Low	Open		An attacker monitors internal communications and gains visibility into AI-generated instructions or operational state information.	Use encrypted communication channels and restrict network access to authorized devices.
26	Raspberry Pi Unavailable	Denial of service	Medium	Open		The Raspberry Pi becomes unavailable due to hardware failure, software faults, power loss, or network issues, preventing it from acting as the secondary compute resource.	Continuously monitor connection health and automatically transition to the tertiary Lynx-hosted model when the secondary system becomes unavailable.

Instructions to Gateway (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Modified Tertiary AI Instructions	Tampering	Medium	Open		An attacker modifies instructions generated by the tertiary Lynx-hosted model before they reach the gateway process.	Use authenticated inter-process communication or encrypted local communications and verify message integrity before processing.
27	Disclosure of Local AI Communications	Information disclosure	Low	Open		Internal model outputs or robot command proposals are exposed through local communication channels or misconfigurations.	Restrict access to containers, isolate workloads, and limit visibility of internal communication channels.
28	Tertiary AI Service Unavailable	Denial of service	Low	Open		The Lynx-hosted AI becomes unavailable due to software faults, resource exhaustion, or container failures.	Implement health monitoring and restart policies. If the tertiary service is unavailable, the gateway should transition the robot into a safe state rather than continuing without a valid command source.

RGB-D (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	Manipulated RGB-D Data	Tampering	High	Open		An attacker modifies RGB-D data transmitted from the camera to an AI model. The altered data may cause incorrect object detection, pose estimation, or scene understanding, resulting in inappropriate robot commands being generated.	Communications between the camera and AI systems should be authenticated and integrity protected. AI-generated commands should also be validated independently by the Robot Gateway before reaching the robot.
29	Camera Feed Interception	Information disclosure	Medium	Open		An attacker gains access to RGB-D streams transmitted across the network. Captured data may reveal operational procedures, robot activities, facility layouts, or information about manipulated objects.	Camera traffic should be encrypted and restricted to authorized recipients. Network segmentation should limit visibility of camera streams to approved systems only.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
30	Camera Stream Unavailable	Denial of service	High	Open		The camera stream becomes unavailable due to network failures, hardware faults, power loss, or malicious interference. AI systems may lose visibility of the environment and become unable to generate reliable instructions.	AI models should detect missing or stale image data and stop generating movement instructions. The Robot Gateway should reject commands generated from outdated sensor information and transition the system to a safe state if required.

RGB-D (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	Manipulated RGB-D Data	Tampering	High	Open		An attacker modifies RGB-D data transmitted from the camera to an AI model. The altered data may cause incorrect object detection, pose estimation, or scene understanding, resulting in inappropriate robot commands being generated.	Communications between the camera and AI systems should be authenticated and integrity protected. AI-generated commands should also be validated independently by the Robot Gateway before reaching the robot.
29	Camera Feed Interception	Information disclosure	Medium	Open		An attacker gains access to RGB-D streams transmitted across the network. Captured data may reveal operational procedures, robot activities, facility layouts, or information about manipulated objects.	Camera traffic should be encrypted and restricted to authorized recipients. Network segmentation should limit visibility of camera streams to approved systems only.
30	Camera Stream Unavailable	Denial of service	High	Open		The camera stream becomes unavailable due to network failures, hardware faults, power loss, or malicious interference. AI systems may lose visibility of the environment and become unable to generate reliable instructions.	AI models should detect missing or stale image data and stop generating movement instructions. The Robot Gateway should reject commands generated from outdated sensor information and transition the system to a safe state if required.

Instructions to Gateway (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Cloud Commands Modified in Transit	Tampering	High	Open		An attacker intercepts communications between the cloud-based AI and the Robot Gateway and modifies generated instructions before they are processed by the gateway.	All communications should use authenticated encryption with certificate validation to ensure commands cannot be modified undetected.
23	Exposure of Robot Data	Information disclosure	Medium	Open		Robot state information, or command traffic transmitted to the cloud may be intercepted and observed by unauthorized parties.	Encrypt all traffic and limit transmitted information to the minimum necessary for model operation.
24	Cloud Service Unavailable	Denial of service	Medium	Open		Internet outages, cloud platform outages, or network disruptions may prevent communication between the primary AI and the gateway.	The gateway should automatically fail over to the Raspberry Pi model and continue operation using local resources.

RPI model Secondary (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
40	Raspberry Pi Model Compromise	Elevation of privilege	High	Open		An attacker gains unauthorized access to the Raspberry Pi model container or host system and is able to manipulate model outputs, configuration, or runtime behavior. During failover scenarios, this could allow malicious or unsafe instructions to be forwarded to the Robot Gateway.	The Raspberry Pi should be hardened through secure configuration, restricted administrative access, container isolation, and regular software updates. Commands generated by the model should continue to undergo validation by the Robot Gateway before being considered for execution.
41	Generation of Unsafe Commands	Tampering	Critical	Open		The Raspberry Pi model generates commands that are operationally unsafe due to software defects, incorrect inference results, corrupted inputs, or unexpected operating conditions. These commands may be accepted as valid despite creating safety risks.	The Robot Gateway should independently validate all received commands against safety constraints, workspace limitations, collision avoidance rules, and operational policies.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
42	Unauthorized Modification of Model Configuration	Tampering	High	Open		An attacker modifies model parameters, configuration files, prompts, or supporting software components, causing the Raspberry Pi model to behave differently than intended. This may result in degraded performance or generation of unsafe instructions.	Configuration files should be protected through access controls and integrity verification. Administrative access should be restricted to authorized personnel and configuration changes should be logged.
43	Disclosure of Perception Data	Information disclosure	Medium	Open		RGB-D data, inference outputs, object information, or operational state data processed by the Raspberry Pi may be exposed through logs, debugging interfaces, or unauthorized access to the system.	Access to stored and processed data should be limited to authorized users. Unnecessary services should be disabled and sensitive information should not be retained longer than required.
44	Disclosure of Generated Commands	Information disclosure	Medium	Open		Robot command proposals produced by the Raspberry Pi model may be disclosed to unauthorized users through logs, APIs, or software misconfigurations. This information could reveal system behavior and assist future attacks.	Access to operational data and logs should be restricted and monitored. Generated outputs should only be accessible to authorized components of the system.
45	Raspberry Pi Resource Exhaustion	Denial of service	Medium	Open		High processing loads, insufficient memory, excessive requests, or software faults may exhaust the Raspberry Pi's available resources and prevent timely generation of commands.	Resource limits, service monitoring, and health checks should be implemented. The Robot Gateway should detect degraded model performance and switch to the tertiary model when required.
46	Raspberry Pi Model Unavailable	Denial of service	Medium	Open		The Raspberry Pi model may become unavailable due to hardware failure, container crashes, operating system issues, power loss, or network connectivity problems. This prevents the secondary decision-making path from being used.	The system should continuously monitor model availability and automatically fail over to the Lynx-hosted tertiary model when the Raspberry Pi is unavailable.

Cloud model Primary (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
34	Cloud Model Compromise	Elevation of privilege	Critical	Open		An attacker gains unauthorized access to the cloud model environment and is able to manipulate model behaviour, generated instructions, or associated services. Because the cloud model serves as the primary decision-making component, a compromise could result in the generation of unsafe or malicious robot commands.	The cloud environment should be protected through strong authentication, access controls, network restrictions, and continuous security monitoring. Commands generated by the cloud model should always be independently validated by the Robot Gateway before being considered for execution.
35	Generation of Unsafe Commands	Tampering	Critical	Open		The cloud model generates commands that are syntactically correct but operationally unsafe due to model error, unexpected inputs, hallucinations, or incorrect reasoning. These commands may result in hazardous robot actions if accepted without verification.	The Robot Gateway should validate all commands against predefined safety constraints, workspace limits, and operational policies before forwarding instructions to the robot.
36	Disclosure of Camera Data	Information disclosure	High	Open		The cloud model processes RGB-D data originating from the local environment. Unauthorized access to the cloud environment could expose camera feeds, scene information, object locations, or operational data that may be considered sensitive.	Only the minimum required data should be transmitted to the cloud. Data should be encrypted during transmission and access to stored information should be restricted through appropriate authorization controls.
37	Disclosure of Robot Commands	Information disclosure	Medium	Open		Generated robot instructions and decision outputs may be exposed through logs, debugging interfaces, APIs, or unauthorized access to cloud resources. This information could assist an attacker in understanding system behaviour and planning future attacks.	Access to logs and operational data should be restricted to authorized users. Sensitive outputs should be protected and retained only as long as necessary.
38	Cloud Model Unavailable	Denial of service	Medium	Open		The cloud model may become unavailable due to internet outages, cloud-provider disruptions, resource exhaustion, service failures, or malicious attacks. As the primary compute resource, this would prevent normal operation through the preferred processing path.	The system should automatically transition to the Raspberry Pi secondary model when the cloud model becomes unavailable. Health monitoring and connectivity checks should detect failures and trigger failover procedures.
39	Excessive Resource Consumption	Denial of service	TBD	Open		Unexpected workloads, malformed requests, or malicious activities may consume excessive computational resources within the cloud environment, degrading model performance or preventing timely generation of commands.	Resource limits, monitoring, request validation, and scaling mechanisms should be implemented to ensure predictable service availability under varying workloads.

Robot Gateway (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
19	Execution of Unauthorized Control Commands	Elevation of privilege	Critical	Open		An attacker gains access to the Robot Gateway and is able to execute commands with the privileges of the gateway itself. Since the gateway is responsible for selecting and forwarding robot instructions, successful exploitation could allow complete control over robot behaviour regardless of which AI produced the command.	The gateway should follow the principle of least privilege and run only the services required for operation. Access controls, container isolation, software hardening, and security monitoring should be implemented to reduce the likelihood and impact of compromise.
20	Unsafe AI Command Acceptance	Tampering	Critical	Open		The Robot Gateway receives instructions from one of the AI systems that are syntactically valid but physically unsafe. Without independent validation, dangerous commands could be forwarded directly to the robot.	The gateway should act as a validation layer that verifies workspace limits, speed constraints, collision rules, and operational policies before issuing commands to the robot.
21	Gateway Service Failure	Denial of service	High	Open		The gateway process becomes unavailable because of software faults, container crashes, resource exhaustion, or hardware problems. As the gateway is the central communication path, a failure can prevent robot control entirely.	Implement health monitoring, watchdog mechanisms, automatic container restart policies, and safe-stop procedures for the robot when gateway availability is lost.
22	Disclosure of Robot Commands and Status Information	Information disclosure	Medium	Open		Sensitive operational information such as robot commands, camera-derived decisions, system state, and failover status may be exposed through logs, debugging interfaces, or misconfigured services.	Restrict access to logs and administrative interfaces, disable unnecessary services, and ensure sensitive operational data is appropriately protected.

Camera (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
31	Compromised Camera	Tampering	Critical	Open		An attacker gains control of the camera and manipulates the generated RGB-D data. Because all AI models rely on the same sensor source, a compromised camera can simultaneously influence every decision-making component in the architecture.	The camera should be hardened through secure configuration, firmware management, access control, and network isolation. AI-generated commands should undergo independent safety validation before reaching the robot.
32	False Scene Injection	Tampering	High	Open		An attacker causes the camera to observe misleading information, such as unexpected objects, altered lighting conditions, or deceptive visual patterns. The AI models may interpret this information incorrectly and generate inappropriate robot actions.	Vision results should be validated using confidence thresholds, temporal consistency checks, and additional safety constraints before actions are executed.
33	Camera Resource Exhaustion	Denial of service	Medium	Open		Excessive requests or network traffic overwhelm the camera, reducing throughput or preventing image acquisition entirely. This may degrade perception accuracy or make the perception pipeline unavailable.	Restrict access to authorized systems, implement rate limiting where possible, and continuously monitor camera health and performance.

Lynx model Tertiary (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
47	Lynx Model Compromise	Elevation of privilege	High	Open		An attacker gains unauthorized access to the Lynx-hosted model container and is able to modify model behavior, generated instructions, or supporting software. Although the model serves as a tertiary processing resource, a compromise could still result in unsafe robot commands being proposed to the Robot Gateway.	Container isolation, access controls, and software integrity protections should be implemented on the Lynx platform. Commands generated by the model should continue to be validated by the Robot Gateway before execution.
48	Generation of Unsafe Commands	Tampering	Critical	Open		The Lynx-hosted model generates commands that are operationally unsafe due to inaccurate perception, inference errors, model limitations, or unexpected operating conditions. Unsafe commands may result in hazardous robot actions if accepted without verification.	The Robot Gateway should enforce safety validation independently of the command source. Workspace restrictions, motion limits, collision avoidance rules, and operational constraints should be verified before commands reach the robot.
49	Disclosure of Model Outputs	Information disclosure	Low	Open		Generated command proposals, perception results, or operational status information may be exposed through logs, management interfaces, or software misconfigurations.	Access to logs and operational data should be restricted. Unnecessary services and debugging interfaces should be disabled, and sensitive information should only be retained when operationally required.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
50	Resource Exhaustion	Denial of service	Medium	Open		Excessive workload, software faults, or competing services may consume available computational resources on the Lynx platform, preventing the model from operating reliably.	Resource limits, service monitoring, and automatic recovery mechanisms should be implemented. Critical services should be prioritized to ensure predictable operation under degraded conditions.
51	Lynx Model Unavailable	Denial of service	Medium	Open		The Lynx-hosted model becomes unavailable due to software faults, container failure, hardware issues, or platform instability. As the final computational fallback in the architecture, this may leave no remaining AI processing path.	Health monitoring and automatic restart mechanisms should be implemented to restore service when possible. If no valid processing source remains available, the Robot Gateway should transition the robot to a predefined safe state.